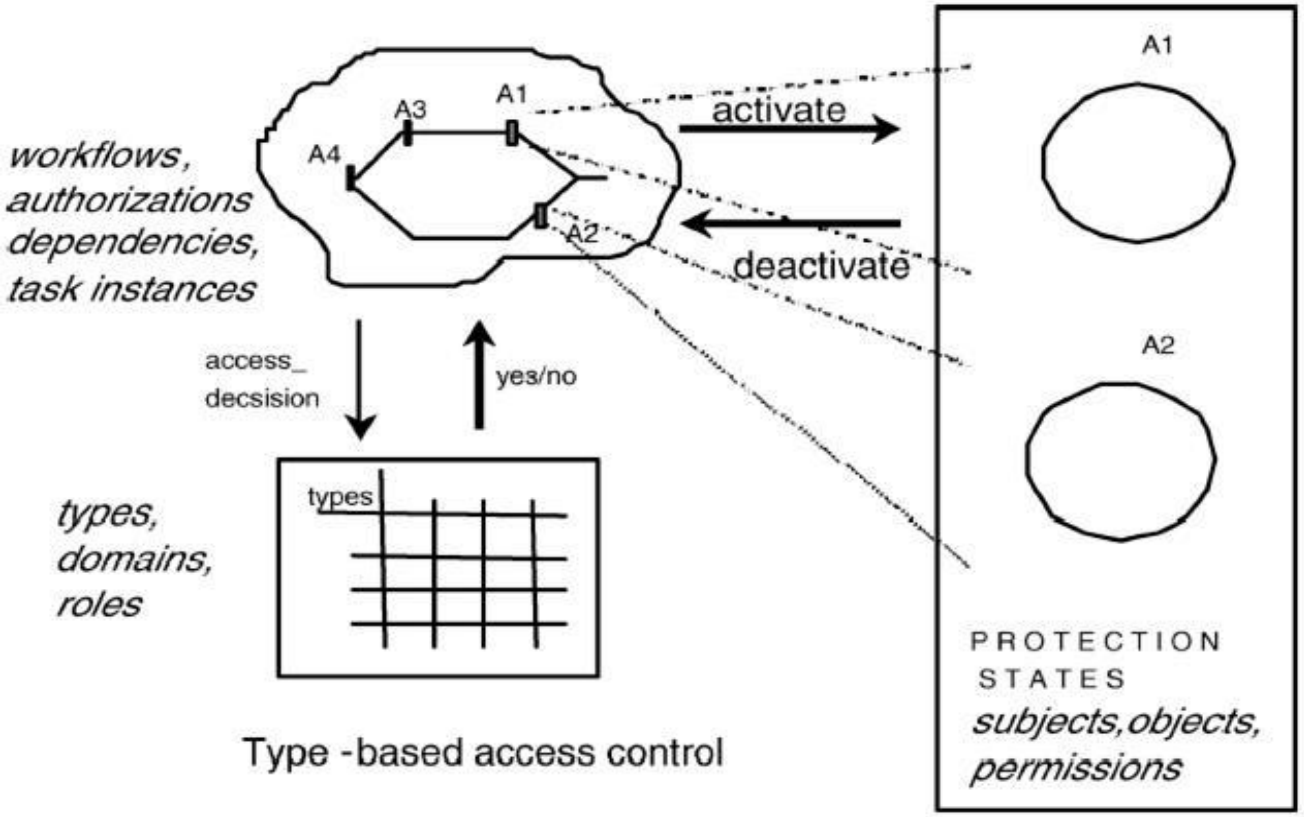
Controlul accesului in sisteme colaborative

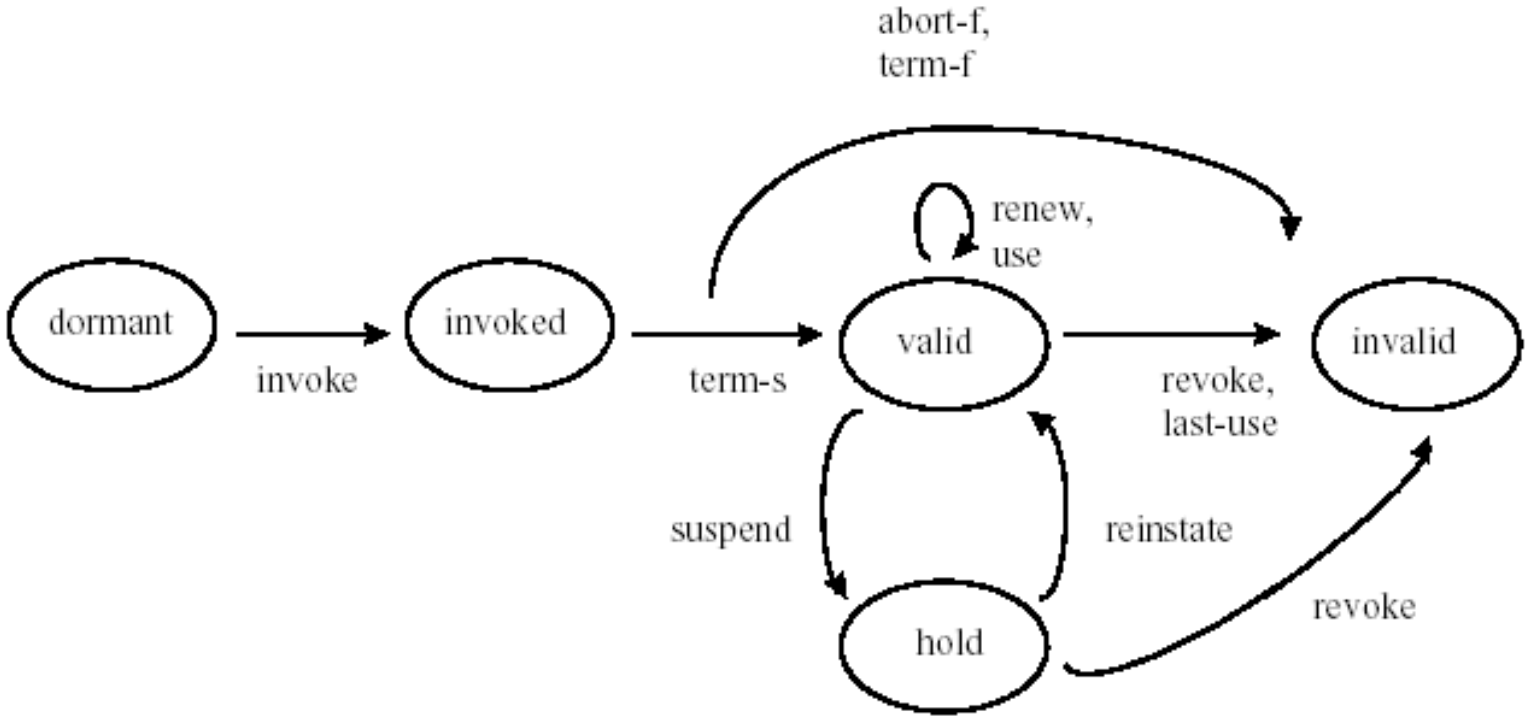
TBAC – Task Based Access Control

- Permisiunile sunt **activate** la inceputul fiecarui task si **dezactivate** la terminarea lui (model de **securitate activa**)
- Setul de permisiuni (**Stare de protectie**) descrie drepturile taskului (subiect) asupra obiectelor
- Combina controlul bazat pe **tipuri** (RBAC) si controlul bazat pe **instanta** si **utilizare**



Type -based access control

Procesarea autorizarii



Ciclu de viata cu mai multe stari:

- este invocat un **pas de autorizare**
- daca prelucrarea lui se termina cu succes devine valid, altfel invalid
- valid – permisiunile sunt activate si pot fi "consumate"
- pe parcurs, permisiunile pot fi suspendate temporar (hold)
- la consumarea permisiunilor (sfarsitul ciclului de viata) pasul de autorizare devine invalid

Caracteristici TBAC

Admite **ciclul de viata** si pasii de procesare a autorizarilor

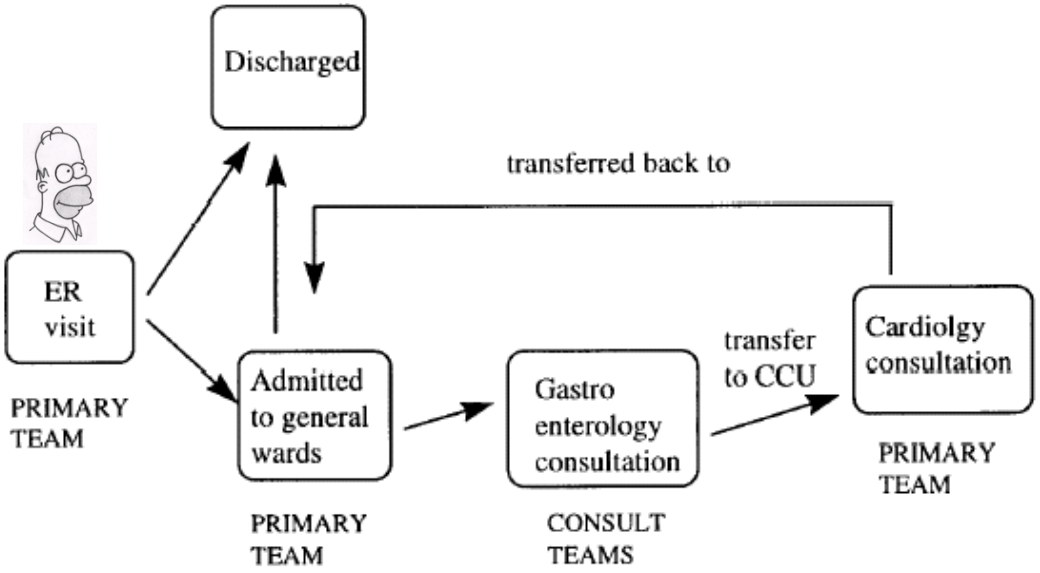
Introduce notiunea de **consum** asociata cu permisiunile (limitarea numarului de accese)

Formeaza baza **auto-administrarii** modelului de securitate (administrare cuplata cu activarea si terminarea taskurilor)

- Limitari
  - contextul este limitat la relatia cu pasii taskului
  - dificultati in specificarea politicilor complexe, a delegarii si revocarii privilegiilor

TMAC - Scenariu

- pacientul vine la camera de garda
- este internat la medicina generala
- echipa decide sa faca o analiza la gastro-enterologie
- in timpul analizei are un atac de cord si este transferat la sectia de cardiologie
- dupa tratament revine la medicina generala
- pacientul se recupereaza si este eliberat din spital.



- personalul este organizat in **echipe** care ingrijesc bolnavul in diverse etape
- fiecare echipa este asociata unui **departament**
- membrii echipelor au **roluri** diferite
- echipele sunt **formate dinamic** (consultatie gastro)

Cerinte pentru controlul accesului

1. permisiunile asociate unui membru reflecta **competentele lui** - cardiologul poate prescrie medicatia pentru atac de cord
2. permisiunile se refera la un **anumit pacient** (obiect)
   - doar **membrii echipelor** de ingrijire a acestui pacient pot avea acces la fisele sale
   - recomandarea pentru gastro o da medicul din echipa acestui pacient
3. accesul este permis in **functie de context**
   - ex. **traseul pacientului** - echipa de generalisti are acces la fise doar cand pacientul a trecut la medicina generala
4. **activare colectiva** a permisiunilor la executie
   - cand pacientul trece la o alta unitate din spital, **noua echipa** are acces la fisa lui, nimeni altcineva
5. membrii pot **delega** permisiunile
   - medicul delega un rezident sa comande un medicament pentru pacient
6. permisiunile pot fi dezactivate
   - cand pacientul paraseste spitalul, permisiunile de acces la fisele sale **inceteaza**

Principalele idei TMAC

O echipa are:

un nume, t.

un set de membri / team users, TU.

un set de team roles, TR $\subseteq$ R (R = setul total de roluri)

un rol special team head (h), h € TR

un set de tipuri de obiecte, OT

un set de instante de obiecte, O

un set de team permissions TP, TP $\subseteq$ TR x OT

un context de colaborare cu doua componente

- user context (UC), UC : TR x TU
- object context (OC), OC : OT x O

Operational

- Primitive de grup
  - User-assign (user, team): asigneaza user la team.
  - User-deassign (user, team): inlatura user din team.
  - Team-activate (team): leaga team permissions la team users si la obiecte (TU si O).
  - Team-deactivate (team): dezactiveaza permisiunile pentru team.
- Primitive individuale
  - User-activate (user): activare permisiuni individual
  - User-deactivate (user): dezactivare permisiuni individual
- Contextul obiectelor se transmite de la o echipa la alta

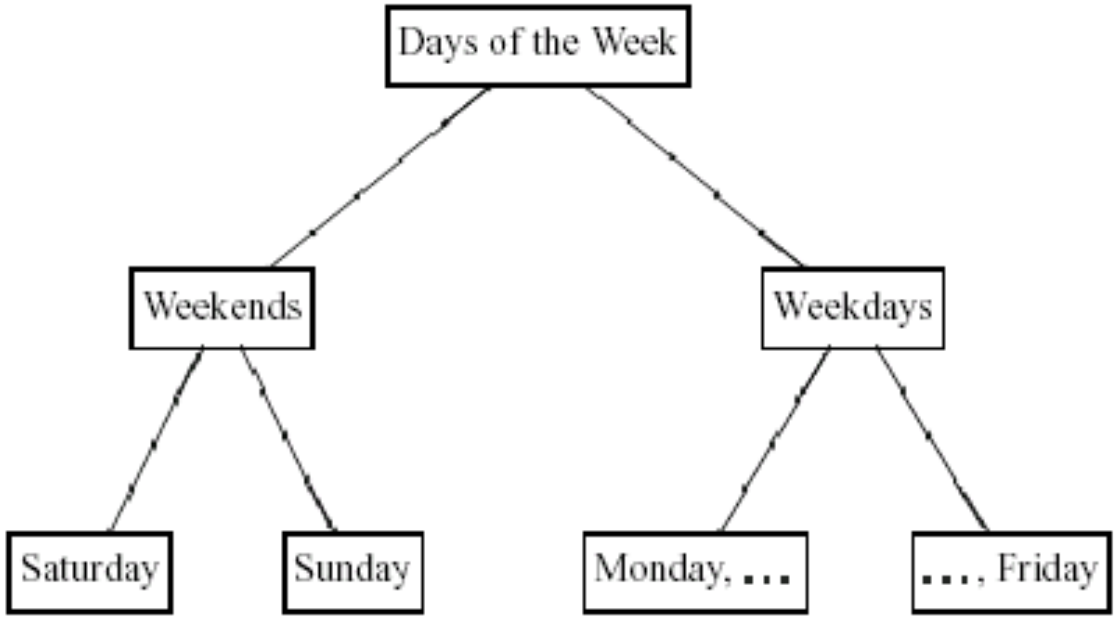
TMAC – Concluzii

- Centrat pe notiunea de echipa – colectie de utilizatori cu roluri diferite dar care au ca obiectiv comun indeplinirea unui task.
- Permisiunile unui subiect depind de
  - rolul sau
  - grupul caruia ii apartine
- Permisiunile sunt
  - asignate unui rol (ca in RBAC) - model de securitate pasiva
  - activate / dezactivate in functie de context - model de securitate activa

Context-Aware Access Control

- Control acces in functie de conditiile de mediu
  - timp: accesul este permis intr-o anumita perioada weekend, weekday
  - loc: acces la un sistem securizat permis daca se face dintr-o incapere securizata fizic
  - incarcarea unui sistem: rolul “high load” este activat la peste 70%
- Extinde RBAC cu “environment roles” care surprind contextul
  - rolurile sunt activate pe baza conditiilor de mediu
  - revocarea se face cand conditiile nu mai corespund rolului

- Rolurile de mediu au caracteristici comune cu cele clasice
  - evitare conflicte (separarea intereselor)
    - uneori se doreste activarea unui singur rol la un moment dat
  - ierarhia de roluri
- unele Environment Roles pot fi activate pe durata unei sesiuni, dar schimbarea conditiilor reclama activarea altor roluri



Modelul

Din RBAC0:

se pastreaza Users, Roles, Permissions si Sessions.

adauga ER si EC,

ER - *Environment Roles*;

EC - *Environment Conditions* folosite in definirea rolurilor.

Relatii UserAssignment, PermissionAssignment

- User Assignment $UA \subseteq U \times R$
- Permission Assignment $PA \subseteq P \times R \times 2^{ER}$
  - PA asociaza o permisiune cu rolul unui subiect si
  - o conditioneaza de un set de environment roles ER active.

Functii care definesc ce roluri utilizator sau de mediu pot fi activate:

- User: S -> 2^R
  - Intr-o sesiune data S, pot fi activate anumite Roluri pentru un User
- Request: EC -> 2ER
  - Pe baza Environmental Conditions, un set de Environment Roles sunt activate la momentul cererii.

O cerere de permisiune *p poate fi* garantata daca:

(1) **p** este in setul de permisiuni asociate rolului r

<p, r, e-set> ϵ PA

(2) Rolul **r** este in setul de roluri active ale utilizatorului care face cererea

(3) environment roles active in conditiile environmentale curente *EC* contin rolurile din ***e-set***.